

被动信息收集

一、被动信息收集概述

1.1 基本概念

被动信息收集（Passive Information Gathering）是指在不与目标系统、网络或个体发生直接交互的前提下，通过利用公开可用的资源与数据获取情报的方法。其核心特征是**隐秘性**——操作过程不会与目标服务器建立连接，因而不会触发防御机制、留下访问日志或引起目标警觉。

被动信息收集广泛应用于以下领域：

- 网络安全与渗透测试**：渗透测试前期的目标侦察阶段（Reconnaissance）
- 开源情报（OSINT）**：基于公开数据源的情报分析
- 竞争情报分析**：了解竞争对手的技术方向与业务动态
- 背景调查与风险评估**：评估组织或个人的可信度与潜在风险

1.2 可收集的信息类型

信息类别	主要内容	典型来源
基础身份信息	姓名、邮箱、电话、地址	WHOIS、社交媒体、招聘网站
网络基础设施	IP 地址、子域名、DNS 记录、服务器位置	DNS 查询、Shodan、Censys
技术栈与服务	编程语言、框架、CMS、云服务	招聘信息、GitHub、网站历史版本
组织结构	员工姓名、职位、部门、联系方式	LinkedIn、公司官网、社交媒体
公开文件与元数据	PDF/Word 内容、图片 EXIF 数据	搜索引擎、Wayback Machine、公开下载链接
历史数据	网站旧版本、已删除页面、过往活动	Internet Archive (archive.org)
社交与行为数据	兴趣爱好、活动轨迹、关联人物	Twitter/X、论坛、博客
泄露信息	用户名、密码、API 密钥	Pastebin、GitHub 公开仓库、数据泄露数据库
业务与运营信息	合作伙伴、客户列表、财务状况	新闻报道、年报、招聘启事

1.3 信息的利用方式

收集到的公开信息在不同场景下具有不同的应用价值：

- 网络安全与渗透测试**：子域名和 IP 地址用于识别攻击面；技术栈信息（如 WordPress 版本）可定向查找已知漏洞；泄露的凭据可在授权范围内尝试登录验证。

- 2. **社会工程学攻击**：员工姓名与邮箱可构建钓鱼邮件；社交媒体信息可用于制作定制化诱饵（如模拟熟人沟通）。
- 3. **竞争情报分析**：业务信息揭示对手战略方向；技术栈可推断其产品研发能力。
- 4. **背景调查**：身份信息和社交数据用于评估个人或组织的可信度；历史数据可发现潜在风险记录。
- 5. **漏洞挖掘**：文件元数据可能暴露内部网络细节；公开文档可能包含敏感配置信息。
- 6. **地理定位**：图片 EXIF 数据或社交媒体签到信息可定位目标的物理位置（如通过员工照片推断办公地点）。

重要提示：被动信息收集技术本身合法，但其成果的使用必须在授权范围内进行。未经授权的攻击行为违反相关法律法规。

二、被动信息收集方法

2.1 搜索引擎利用

搜索引擎利用的核心思路是通过精确查询，从搜索引擎已缓存的网页、文件或公开资源中提取目标相关信息。由于不直接访问目标服务器，属于典型的被动收集方式。目标信息可能是主动公开的（如官网内容），也可能是无意泄露的（如未受保护的配置文件、敏感文档）。

基础操作

使用目标名称或相关关键词进行初步检索：

- 输入目标公司名或 `target.com`，浏览官网、新闻报道、社交媒体信息。
- 适合快速了解目标概况，但结果较为宽泛，需进一步精炼。

高级搜索语法（Google Dorking）

Google 提供了一系列搜索操作符，可大幅缩小范围并精准定位目标信息，此技术通常称为 **Google Dorking**：

语法	用途	示例	预期效果
<code>site:</code>	限制搜索范围至特定域名	<code>site:target.com</code>	返回目标网站所有被索引页面
<code>-</code> （减号）	排除特定关键词	<code>site:*.example.com -inurl:(www)</code>	查找除主站外的所有子域名
<code>filetype:</code>	搜索特定类型文件	<code>site:target.com filetype:pdf</code>	查找目标站点的 PDF 文件
<code>inurl:</code>	搜索 URL 中含有特定词的页面	<code>site:target.com inurl:admin</code>	查找可能的管理后台入口
<code>intitle:</code>	搜索页面标题包含特定词的结果	<code>site:target.com intitle:"index of"</code>	发现开放的目录列表
<code>" "</code> （引号）	精确匹配短语	<code>site:target.com "password list"</code>	查找包含确切短语的页面
<code>*</code> （通配符）	模糊匹配	<code>site:target.com "user *login"</code>	匹配多种变体形式

典型查询示例

操作目标	查询示例	预期效果
搜索敏感文件	site:example.com filetype:txt password	查找可能包含密码的文本文件
	site:example.com filetype:csv "user data"	搜索可能泄露用户数据的 CSV 文件
	site:example.com filetype:sql -inurl:signup	查找 SQL 数据库导出文件
寻找后台入口	inurl:(cpanel \ phpadmin)	查找常见管理工具入口
	site:example.com inurl:wp-admin -inurl:login	搜索 WordPress 管理后台
历史泄露信息	site:pastebin.com example.com	检查 Pastebin 上是否有目标数据泄露
	site:github.com "example.com" api_key	搜索 GitHub 上相关 API 密钥泄露

2.2 社交媒体分析

社交媒体平台是获取目标组织人员架构与行为信息的重要渠道。常用平台包括：

- **职业类**：LinkedIn（职位、技能、工作经历）、脉脉
- **社交类**：微博、Twitter/X（动态、地理位置）、微信公众号
- **技术类**：GitHub（代码、注释、提交历史）、技术论坛

主要收集内容：员工姓名、职位、联系方式、公司活动、地理位置标记，以及照片的 EXIF 元数据（可能包含拍摄时间和 GPS 坐标）。

参考视频资料：[如何通过一张照片锁定一个人的位置？网络迷踪](#)

2.3 域名与 WHOIS 查询

域名基础

域名（Domain Name）是互联网上网站地址的人类可读标识，通过域名系统（DNS）解析为机器识别的 IP 地址。例如，`hnpi.edu.cn` 解析后指向具体服务器的 IP 地址。

WHOIS 查询原理

WHOIS 是一种用于查询域名注册信息的协议与服务。通过查询由域名注册商（如 GoDaddy、阿里云）或区域互联网注册机构（如 ICANN、CNNIC）维护的 WHOIS 数据库，可获取：

- 域名注册人信息（姓名、单位、联系方式）
- 注册时间与到期时间
- 域名注册商及名称服务器信息

WHOIS 查询属于被动信息收集，因其依赖公开注册数据，无需与目标服务器交互。

注意：受隐私保护政策影响，WHOIS 查询结果的完整性有所下降。欧洲 GDPR 法规要求部分欧洲域名注册人信息不得公开；国内许多域名注册商也提供"WHOIS 隐私保护"服务，以代理信息替代真实注册人信息。

常用查询方式

命令行方式 (Kali Linux 内置 whois 工具)：

```
whois hnpi.cn
```

```
(kali㉿kali)-[~]
└─$ whois hnpi.cn
Domain Name: hnpi.cn
ROID: 20060404s10001s48518454-cn
Domain Status: ok
Registrant: 河南工业职业技术学院
Registrant Contact Email: 390675671@qq.com
Sponsoring Registrar: 北京新网数码信息技术有限公司
Name Server: 222.88.88.88
Name Server: 114.114.114.114
Registration Time: 2006-04-04 15:59:56
Expiration Time: 2027-04-04 15:59:56
DNSSEC: unsigned
```

在线工具：

- [域名 WHOIS 查询 - 站长工具 \(chinaz.com\)](#)
- [ICP 备案查询 - 站长工具 \(chinaz.com\)](#)

域名 hnpi.cn 的信息 求购此域名 以下信息更新时间: 2024-02-05 19:27:53 立即更新 获取API	
域名	hnpi.cn 申请删除隐私
	其他常用域名后缀查询: cn com cc net org
注册商	北京新网数码信息技术有限公司
联系人	河南工业职业技术学院 [whois反查]
联系邮箱	****75671@qq.com [whois反查]
创建时间	2006年04月04日
过期时间	2027年04月04日
状态	正常(ok)

补充说明：ICP 备案查询是中国特有的信息渠道。根据国内法规，所有在中国大陆运营的网站须完成 ICP 备案，备案信息中包含网站主办单位名称、备案号及主办人信息，是针对国内目标的重要信息来源。

2.4 DNS 信息收集

DNS 信息收集是指通过分析目标域名的 DNS 记录，获取其网络基础设施信息的过程。DNS (Domain Name System, 域名系统) 是互联网的核心组件，负责将域名解析为 IP 地址。DNS 记录本身是公开可查询的，因此属于被动信息收集范畴，不会与目标服务器直接交互。

通过 DNS 信息收集，可以了解目标的网络架构、服务器分布、子域名、邮件系统等关键细节。

常见 DNS 记录类型

记录类型	描述	示例
A 记录 (Address)	域名对应的 IPv4 地址	example.com → 93.184.216.34
AAAA 记录	域名对应的 IPv6 地址	example.com → 2606:2800:220:1::93
MX 记录 (Mail Exchange)	邮件服务器域名及优先级	mail.example.com (priority 10)
NS 记录 (Name Server)	负责解析该域名的权威名称服务器	ns1.example.com
CNAME 记录 (Canonical Name)	域名别名, 指向另一个域名	www.example.com → example.com
TXT 记录	文本信息, 常用于 SPF、DKIM 验证	v=spf1 include:_spf.google.com ~all
SOA 记录 (Start of Authority)	区域权威信息, 含主服务器及管理员邮箱	admin@example.com
SRV 记录 (Service)	特定服务的位置信息 (如 SIP、XMPP)	_sip._tcp.example.com
PTR 记录 (Pointer)	IP 到域名的反向解析	93.184.216.34 → example.com

常用查询工具

`dig` (Linux/macOS, 功能强大) :

```
# 查询 A 记录
dig example.com A

# 查询 MX 记录
dig example.com MX

# 查询所有记录类型
dig example.com ANY

# 指定 DNS 服务器查询
dig @8.8.8.8 example.com
```

```

(kali@kali)-[~]
$ dig hnp1.edu.cn ANY

; <<>> DiG 9.20.2-1-Debian <<>> hnp1.edu.cn ANY
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 61006
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:;, udp: 512
;; QUESTION SECTION:
;hnp1.edu.cn.                IN      ANY

;; ANSWER SECTION:
hnp1.edu.cn.                231     IN      A       125.219.112.6
hnp1.edu.cn.                109     IN      NS      dns4.hnp1.edu.cn.
hnp1.edu.cn.                109     IN      NS      dns.hnp1.edu.cn.
hnp1.edu.cn.                109     IN      NS      dns2.hnp1.edu.cn.
hnp1.edu.cn.                109     IN      NS      dns3.hnp1.edu.cn.

;; Query time: 23 msec
;; SERVER: 192.168.127.2#53(192.168.127.2) (TCP)
;; WHEN: Tue Feb 25 20:18:15 EST 2025
;; MSG SIZE rcvd: 131

```

nslookup (跨平台, Windows/Linux/macOS 均可用) :

基础查询

```
nslookup example.com
```

查询指定记录类型

```
nslookup -type=MX example.com
```

```

(kali@kali)-[~]
$ nslookup -type=MX hnp1.edu.cn
Server:      192.168.127.2
Address:     192.168.127.2#53

Non-authoritative answer:
hnp1.edu.cn  mail exchanger = 5 mxbiz1.qq.com.
hnp1.edu.cn  mail exchanger = 10 mxbiz2.qq.com.

Authoritative answers can be found from:

```

DNSdumpster (在线工具, 可视化展示 DNS 记录与子域名) :

A Records (subdomains from dataset)					
Host	IP	ASN	ASN Name	Open Services (from DB)	RevIP
cwwx.hnp1.edu.cn	125.219.112.152	ASN:4538 125.219.112.0/22	ERX-CERNET-BKB China Education and Research Network Center, CN China		1
dns.hnp1.edu.cn	125.219.112.8	ASN:4538 dns.hnp1.edu.cn 125.219.112.0/22	ERX-CERNET-BKB China Education and Research Network Center, CN China	https: nginx title: 403 Forbidden cn: 10.0.0.1 o: SecWorld tech: Nginx	1
dns2.hnp1.edu.cn	218.28.91.99	ASN:4837 pc0.zz.ha.cn 218.28.0.0/15	CHINA169-BACKBONE CHINA UNICOM China169 Backbone, CN China	https: nginx title: 403 Forbidden cn: 10.0.0.1 o: SecWorld tech: Nginx	1
dns3.hnp1.edu.cn	222.88.238.8	ASN:4134 222.88.0.0/15	CHINANET-BACKBONE No.31,Jin-rong Street, CN China		1
jwg1.hnp1.edu.cn	125.219.112.30	ASN:4538 125.219.112.0/22	ERX-CERNET-BKB China Education and Research Network Center, CN China		1
www.hnp1.edu.cn	218.28.91.101	ASN:4837 pc0.zz.ha.cn 218.28.0.0/15	CHINA169-BACKBONE CHINA UNICOM China169 Backbone, CN China	http: unknown server title: 403 Forbidden https: unknown server title: 403 Forbidden cn: .hnp1.edu.cn	1

DNSdumpster (dnsdumpster.com) 可以将目标域名的 DNS 记录以图形方式呈现, 包括子域名关系、MX 服务器分布等, 便于快速理解目标网络结构。

2.5 公开文档、网络存档与历史记录

公开文档

公开文档是指由组织、企业、政府或学术机构合法对外发布的文件，通常用于满足信息透明度要求或对外宣传。常见类型包括：

- 企业年报（可在官网、证券交易所网站获取）
- 政府政策文件与法规公告
- 学术论文与专利申请
- 招标文件与投标文件（可能包含技术方案、系统架构等敏感信息）

这些文档往往被忽视，但可能包含内部联系人、技术架构、合作伙伴等有价值的情报。

Pastebin

[Pastebin \(pastebin.com\)](https://pastebin.com) 是一个在线文本粘贴与分享平台，允许用户将代码、日志、数据等文本内容生成短链接对外分享，最初面向开发者设计。

从信息安全角度，Pastebin 是重要的泄露信息监测渠道：

- 攻击者常将窃取的数据库、用户凭据（用户名/密码）发布至此
- 开发者可能将包含 API 密钥、数据库连接串的代码片段无意上传
- 内部人员有时通过此渠道传递消息或临时共享数据

可配合 Google Dork `site:pastebin.com "目标关键词"` 检索与目标相关的泄露记录。

Internet Archive 与 Wayback Machine

[Internet Archive \(archive.org\)](https://archive.org) 是由非营利组织于 1996 年创立的数字图书馆，致力于保存网页、书籍、音频、视频、软件等互联网内容。

其核心工具 **Wayback Machine** 通过定期抓取并存储网页快照，允许用户访问网站在过去某一时间点的历史版本，主要用途包括：

- 查看目标网站的历史页面结构与内容
- 发现已被删除但仍具情报价值的信息（如旧版联系人、产品信息）
- 对比不同时期的网站变化，推断目标的技术演进路径

使用方式：访问 web.archive.org，在搜索框输入目标 URL，即可查看历史快照时间轴。

2.6 商业信息查询平台

针对国内目标，工商注册信息、司法记录等是重要的公开情报来源。常用平台包括：

- **天眼查** (tianyancha.com)：提供企业工商注册、股权结构、法人信息、司法风险等查询
- **企查查** (qcc.com)：功能类似天眼查，同样提供企业基础信息与风险数据
- **国家企业信用信息公示系统** (gsxt.gov.cn)：工商行政管理局官方数据，信息权威

这类平台可查询到企业法定代表人、注册地址、联系电话、关联企业等信息，是针对国内企业目标侦察的重要渠道。

三、网络空间搜索引擎

3.1 概述与分类

网络空间搜索引擎（Cyberspace Search Engine）是一类专门用于搜索和索引互联网公开暴露设备、服务与基础设施信息的工具。与传统搜索引擎（如 Google、百度）索引网页内容不同，网络空间搜索引擎的目标是发现和分析联网设备、开放端口、运行服务以及潜在的安全风险。

传统搜索引擎与网络空间搜索引擎的区别：

特性	传统搜索引擎	网络空间搜索引擎
搜索目标	网页、图片、视频	联网设备、开放端口、服务
数据来源	网站发布内容	IP 扫描、端口探测、Banner 抓取
使用场景	日常信息查询	安全分析、资产发现、漏洞研究
代表工具	Google、百度	Shodan、Censys、ZoomEye、FOFA

3.2 主流网络空间搜索引擎

Shodan

[Shodan \(shodan.io\)](https://shodan.io) 是目前最知名的网络空间搜索引擎，常被称为"黑客的搜索引擎"。它通过持续扫描全球 IP 地址，抓取设备开放端口上的 Banner 信息，建立涵盖路由器、摄像头、工业控制系统、数据库等各类联网设备的索引。

- 每日更新，实时性强
- 生态丰富，支持 API 集成与第三方插件
- 免费版功能受限（每月查询次数有限），完整功能需付费订阅

Censys

[Censys \(censys.io\)](https://censys.io) 由密歇根大学研究团队开发，专注于对全互联网 IP 地址、开放端口及 TLS/SSL 证书进行系统性扫描与分析，数据质量较高，适合学术研究与安全分析。

- 免费提供基础搜索能力，高级功能需企业订阅
- 在证书分析与漏洞检测方面具有优势

ZoomEye

[ZoomEye \(zoomeye.org\)](https://zoomeye.org) 由知道创宇（KnownledgedSec）开发，是国内领先的网络空间搜索引擎，功能类似 Shodan，对国内设备的覆盖具有一定优势。

- 支持中文界面，适合国内用户
- 提供威胁情报监控与 IPv6 搜索能力

FOFA

[FOFA \(fofa.info\)](https://fofa.info) 由白帽汇（Baimaohui）开发，专注于网络资产管理与漏洞发现，提供设备指纹识别与地理定位能力。

- 中文界面，对国内网络资产覆盖较好
- 支持丰富的指纹规则，适合企业资产梳理与暴露面管理

主流工具横向对比：

特性	Shodan	Censys	ZoomEye	FOFA
数据覆盖	全球，设备种类多	全球，数据质量高	全球，偏重国内	国内强，全球中等
更新频率	高（每日）	高（略逊于 Shodan）	中低（数天一次）	中等
免费版限制	严格	较宽松	中等	严格
核心优势	实时性，生态丰富	数据质量，漏洞检测	威胁监控，IPv6	国内支持，指纹识别
界面语言	英文	英文	中英文	中文

3.3 Shodan 基本使用方法

界面说明

在 Shodan 主页搜索框中输入关键词（如 `SSH`）后，搜索结果页面分为两个区域：

左侧汇总统计面板：

- Results Map：搜索结果地理分布地图
- Top Services (Ports)：最常见的服务与端口
- Top Organizations (ISPs)：使用最多的组织/ISP
- Top Operating Systems：最常见的操作系统
- Top Products：最常见的软件与产品

中间主结果列表（每条结果包含）：

- IP 地址
- 主机名
- ISP 归属
- 数据收录时间
- 地理位置（国家/城市）
- Banner 信息（端口响应原始内容）

ShodanDevelopersBookView All...

SHODANSSHExploreDeveloper PricingEnterprise Access

ExploitsMapsImages

TOTAL RESULTS

20,993,182

TOP COUNTRIES



United States	8,194,886
China	1,521,978
Germany	1,455,361
France	927,428
Russian Federation	641,578

TOP SERVICES

SSH	19,386,622
2222	828,124
Synology	149,128
HTTPS	51,297
mDNS	51,106

TOP ORGANIZATIONS

Amazon.com	1,788,474
Google Cloud	1,046,464
Digital Ocean	737,904
OVH SAS	521,563
Choopa, LLC	336,927

TOP OPERATING SYSTEMS

Linux 3.x	188,411
Linux 2.6.x	40,301
Windows 7 or 8	7,610
FreeBSD 9.x	3,427
Linux 2.4.x	785

RELATED TAGS: 1 3

35.220.163.244

244.163.220.35.bc.googleusercontent.com

Google Cloud

Added on 2019-02-23 12:19:36 GMT

United States, Mountain View

SSH-2.0-OpenSSH_7.4

Key type: ssh-ed25519

Key: AAAAC3NzaC1lZD11NTE5AAAAIz0cn56ZT/OrYHg13PgU3xtn/XBSS12+15Zr7J5VMN

Fingerprint: 84:01:79:7d:1a:91:b5:9a:cd:74:84:15:2d:7b:dd:6f

Kex Algorithms:

curve25519-sha256

curve25519-sha256@libssh.org

ecdh-sha2-nistp256

ecdh-sha2-nistp384

ecdh-sha2-nis...

43.241.217.136

Beijing Sankuai Technology Co.,Ltd.

Added on 2019-02-23 12:19:39 GMT

China

SSH-2.0-OpenSSH_6.4

Key type: ecdsa-sha2-nistp256

Key: AAAAE2VjZmhlLnNoYXNzaC1lZD11NTE5AAAAIbmlzdHAYNTYAAABBBjMwondTAAa0/1DzvKfWY06L

Fingerprint: f845X6unD2+e2tpmy/kajmzVuK0xzEATZcpXodS08ACy+8oDuJufK4sQP53kLvA=

Fingerprint: 6b:f8:1f:63:b4:ce:de:1b:f8:ff:ab:06:8e:a2:86:79

Kex Algorithms:

ecdh-sha2-nistp256

e...

83.212.72.24

snf-3296-ek-kno-grnetcloud.net

Hosted VM's for OKEANOS project

Added on 2019-02-23 12:19:36 GMT

Greece

SSH-2.0-OpenSSH_7.4p1 Debian-10+deb9u2

Key type: ssh-ed25519

Key: AAAAC3NzaC1lZD11NTE5AAAAIKNLBYHa+KR51Bqt1L/cjDme0ze150163DLAscGWB2h

Fingerprint: 59:55:d5:0d:39:53:52:27:4a:03:a2:6c:57:5e:9e:0d

Kex Algorithms:

curve25519-sha256

curve25519-sha256@libssh.org

ecdh-sha2-nistp256

ecdh-sha2-nist...

点击某条结果可进入主机详情页（URL 格式为 `https://www.shodan.io/host/[IP]`），可查看：

- 主机地理位置（地图标注）
- 主机基本信息（ISP、组织、操作系统）
- 所有开放端口列表及对应 Banner 详情

ShodanDevelopersBookView All...

SHODANSSHExploreDeveloper PricingEnterprise Access

New to Shodan?



43.241.217.136

Country	China
Organization	Beijing Sankuai Technology Co.,Ltd.
ISP	China Unicom Beijing
Last Update	2019-02-23T12:19:39.037972
ASN	AS4808

Vulnerabilities

Note: the device may not be impacted by all of these issues. The vulnerabilities are implied based on the software and version.

CVE-2014-2532	sshd in OpenSSH before 6.6 does not properly support wildcards on AcceptEnv lines in sshd_config, which allows remote attackers to bypass intended environment restrictions by using a substring located before a wildcard character.
CVE-2018-15919	Remotely observable behaviour in auth-gss2.c in OpenSSH through 7.8 could be used by remote attackers to detect existence of users on a target system when GSS2 is in use. NOTE: the discoverer states 'We understand that the OpenSSH developers do not want to treat such a username enumeration (or "oracle") as a vulnerability.'
CVE-2017-15906	The process_open function in sftp-server.c in OpenSSH before 7.6 does not properly prevent write

Ports

22 123 3389 5253 8080

Services

22tcpssh

OpenSSH Version: 6.4

SSH-2.0-OpenSSH_6.4

Key type: ecdsa-sha2-nistp256

Key: AAAAE2VjZmhlLnNoYXNzaC1lZD11NTE5AAAAIbmlzdHAYNTYAAABBBjMwondTAAa0/1DzvKfWY06L

Fingerprint: f845X6unD2+e2tpmy/kajmzVuK0xzEATZcpXodS08ACy+8oDuJufK4sQP53kLvA=

Fingerprint: 6b:f8:1f:63:b4:ce:de:1b:f8:ff:ab:06:8e:a2:86:79

Kex Algorithms:

ecdh-sha2-nistp256

ecdh-sha2-nistp384

ecdh-sha2-nistp521

diffie-hellman-group-exchange-sha256

diffie-hellman-group-exchange-sha1

diffie-hellman-group14-sha1

diffie-hellman-group1-sha1

搜索过滤语法

单纯使用关键词搜索往往结果过于宽泛，Shodan 提供了丰富的过滤语法以精确定位目标：

过滤器	说明	示例
hostname:	按主机名或域名过滤	hostname:"google"
port:	按开放端口过滤	port:"21"
country:	按国家代码过滤 (ISO 3166)	country:"CN"
city:	按城市名过滤	city:"Hefei"
org:	按组织或公司名过滤	org:"google"
isp:	按 ISP 供应商过滤	isp:"China Telecom"
product:	按软件/平台名过滤	product:"Apache httpd"
version:	按软件版本过滤	version:"1.6.2"
geo:	按经纬度坐标过滤	geo:"31.8639, 117.2808"
before/after:	按收录时间过滤 (格式: dd-mm-yy)	before:"11-11-15"
net:	按 IP 地址或子网段过滤 (CIDR)	net:"210.45.240.0/24"
os:	按操作系统过滤	os:"Windows Server 2019"

组合使用示例：

```
# 查找中国境内开放 3389 端口 (RDP) 的 windows 服务器
port:3389 country:"CN" os:"Windows"

# 查找指定网段内运行 Apache 的主机
net:"192.168.1.0/24" product:"Apache httpd"

# 查找暴露在公网的 MongoDB 数据库
product:"MongoDB" port:27017
```

3.4 搜索实例

示例一：暴露在公网的网络摄像头

部分老旧摄像头 Web 管理界面会在 Banner 中返回特征字符串，可用于定向搜索：

```
# 搜索使用 JAWS Web Server 的摄像头
JAWS/1.0
http://219.85.60.173:8080/view2.html

# 搜索海康威视摄像头
www-Authenticate: Basic realm="HiNetworkCamera"
```

注意：对未经授权的设备进行访问或操控，违反《网络安全法》等相关法规，本示例仅供安全研究学习使用。

示例二：AList 网盘服务

AList 是一款开源的文件列表程序（[GitHub 项目地址](#)），部分用户将其直接暴露在公网且未设置访问控制。

Shodan/FOFA 搜索关键字：

```
title="AList"
```

典型公开资源站示例：<http://alist.xiaoya.pro>

示例三：未授权的 Ollama 大模型服务

[Ollama](#) 是一款用于本地部署和运行大语言模型的工具，支持运行 DeepSeek、Llama 等主流模型。部分用户在服务器上部署后未做访问限制，导致 API 接口暴露在公网。

本地启动模型示例：

```
ollama run deepseek-r1:1.5b
```

Shodan/FOFA 搜索关键字：

```
title="Ollama"  
port:11434
```

四、综合 OSINT 工具

4.1 Maltego

Maltego 是由 Maltego Technologies 开发的一款专业级开源情报（OSINT）分析与数据可视化平台，广泛应用于渗透测试前期侦察、威胁情报分析及网络安全调查领域。

核心功能：

- 多源数据整合：**通过集成 DNS 记录、WHOIS 数据、社交媒体、搜索引擎等数百个公开数据源，从单一输入（如域名、邮箱、人名）自动扩展出关联数据（IP 地址、社交账号、相关文件等）。
- 图形化关系展示：**以节点（实体）和边（关系）构建可视化图谱，直观呈现目标与周边关联实体之间的网络关系，即使是多跳间接关联也能清晰展现。
- 变换功能（Transforms）：**对选定实体执行特定查询操作，例如"从域名查找相关 IP"或"从邮箱查找社交账号"。变换支持内置免费选项、付费数据源及用户自定义扩展。
- 跨平台支持：**适用于 Windows、Linux 和 macOS，已默认内置于 Kali Linux 系统。

版本说明：

- Maltego CE（社区版）：**免费，功能受限（每月变换次数有上限），适合学习入门与小规模使用。
- Maltego Professional/Enterprise：**付费版，提供更多变换能力、更大数据处理规模及商业技术支持。

4.2 SpiderFoot

SpiderFoot 是由 Steve Micallef 开发的开源自动化 OSINT 工具（MIT 许可证，Python 编写），能够针对指定目标自动从多个公开数据源收集和关联信息。

核心功能：

- 自动化多源收集：**集成超过 200 个模块，可从 DNS、WHOIS、Shodan、HackerOne、GitHub、社交媒体等 100 余个数据源中提取信息。

- 2. **广泛目标支持**: 支持 IP 地址、域名、主机名、子网 (ASN)、电子邮件、电话号码、用户名、人名等多种目标类型。
- 3. **模块化协作**: 各模块采用发布/订阅机制相互协作，一个模块的输出可作为另一个模块的输入，形成链式数据扩展。
- 4. **双重用途**:
 - **进攻性**: 渗透测试前期侦察，快速建立目标画像
 - **防御性**: 帮助组织自查在互联网上的暴露信息，发现未受保护资产或数据泄露风险
- 5. **操作界面**: 提供 Web 图形界面 (可视化操作) 与命令行界面 (适合脚本化批量处理)。

安装与启动:

```
# 克隆项目
git clone https://github.com/smicallef/spiderfoot

# 进入目录并安装依赖
cd spiderfoot
pip3 install -r requirements.txt

# 启动 web 界面 (监听本地 5001 端口)
python3 sf.py -l 127.0.0.1:5001
```

启动后，通过浏览器访问 `http://127.0.0.1:5001`，在 Web 界面中创建扫描任务：输入目标、选择所需模块，运行后查看关联分析结果。

版本说明:

- **SpiderFoot 开源版**: 免费，适合个人及小规模使用，需本地部署。
- **SpiderFoot HX (商业云版)**: 提供多目标扫描、持续监控等高级功能，无需本地安装。

五、本章小结

被动信息收集是渗透测试与安全评估的重要前置环节，其核心价值在于在不暴露自身意图的前提下，尽可能全面地了解目标的网络资产、人员架构与技术状况，为后续工作提供决策依据。

本章涵盖的主要技术与工具如下：

类别	技术/工具	主要用途
搜索引擎利用	Google Dorking	查找敏感文件、后台入口、泄露信息
社交媒体分析	LinkedIn、微博、GitHub	人员信息、技术栈、行为轨迹
域名信息	WHOIS、ICP 备案	注册人、联系方式、域名历史
DNS 分析	dig、nslookup、DNSdumpster	子域名、服务器分布、邮件系统
历史存档	Wayback Machine、Pastebin	历史页面、泄露信息
商业信息	天眼查、企查查	企业工商、股权、司法风险
网络空间搜索	Shodan、Censys、FOFA、ZoomEye	暴露设备、开放端口、服务指纹
综合 OSINT	Maltego、SpiderFoot	多源数据整合、关系可视化

伦理与合规提示：上述工具和技术均基于公开可访问的数据，其本身的使用是合法的。但收集所得信息的进一步利用必须在明确授权的范围内进行。未经授权的渗透行为违反《中华人民共和国网络安全法》及相关法规，学习者应严格遵守职业道德规范与法律边界。